

Máster en Inteligencia Artificial
para Liderazgo Técnico y Transformación Empresarial

NIST AI RMF: Framework de Gestión de Riesgos de IA

Módulo 13 · Gobernanza, Ética y Regulación

Cuatro funciones Govern/Map/Measure/Manage, 12 riesgos GenAI, integración con EU AI Act e ISO 42001.

1. Introducción · 2. Qué es · 3. Cómo funciona · 4. Ejemplos reales
5. Errores comunes · 6. Aplicación práctica · 7. Relación con módulos · 8. Resumen ejecutivo

Guía de estudio detallada · +2.000 palabras

NIST AI RMF: Framework de Gestión de Riesgos de IA

El NIST AI Risk Management Framework (AI RMF 1.0) fue publicado en enero 2023 por el Instituto Nacional de Estándares y Tecnología de EE.UU. (NIST). Es un framework voluntario diseñado para ayudar a las organizaciones a gestionar los riesgos de los sistemas de IA a lo largo de todo su ciclo de vida. No es regulación vinculante (excepto para proveedores de modelos frontier que deben entregar resultados de red teaming al gobierno de EE.UU. según el Executive Order 14110), pero se ha convertido en el estándar de facto más influyente para la gestión de riesgos de IA en el mundo.

En julio 2024, NIST publicó el NIST-AI-600-1, el perfil del AI RMF específico para IA generativa, que identifica 12 riesgos específicos de los LLMs y sistemas de IA generativa (incluyendo alucinaciones, privacidad de datos, sesgo sistémico, y derechos de autor). En abril 2026, NIST publicó un concepto para un perfil de IA en infraestructura crítica. En 2025, la mayoría de las organizaciones integran el NIST AI RMF con ISO/IEC 42001, el EU AI Act, y los sistemas de gestión de cumplimiento existentes.

Las cuatro funciones del NIST AI RMF

GOVERN: crear la cultura de gestión de riesgos

La función Govern establece los procesos organizativos, las políticas, y la cultura de gestión de riesgos de IA. Incluye: políticas y estrategias de gestión de riesgos de IA alineadas con los valores organizativos, asignación de roles y responsabilidades para la gestión de riesgos, procesos de escalación y toma de decisiones, formación y concienciación sobre riesgos de IA, y gestión de riesgos de terceros (proveedores de modelos, datasets, etc.). Govern aplica a todas las fases del ciclo de vida del sistema y establece el contexto para las otras tres funciones.

MAP: categorizar y contextualizar los riesgos

La función Map identifica los riesgos del sistema de IA en su contexto específico. Incluye: mapear el sistema de IA (propósito, capacidades, datos, stakeholders afectados, dependencias), identificar los riesgos relevantes para ese sistema y contexto, y establecer tolerancias de riesgo. El AI RMF 1.0 introduce el concepto de AI inventory: las organizaciones deben mantener un registro de todos sus sistemas de IA con información sobre su propósito, datos, exposición al riesgo, puntos de integración, y expectativas de supervisión humana.

MEASURE: evaluar y medir los riesgos

La función Measure aplica métricas y evaluaciones para cuantificar los riesgos identificados en Map. Incluye: evaluaciones de seguridad (testing adversarial, evaluaciones de robustez), evaluaciones de fairness (análisis de sesgos en los datos y en los outputs), evaluaciones de privacidad (privacy impact assessments), evaluaciones de explicabilidad (¿se puede explicar la decisión del sistema?), y monitorización continua de los riesgos a lo largo del tiempo. NIST enfatiza siete atributos de IA trustworthy: validez, seguridad, fiabilidad, accountability,

explicabilidad, privacidad, y fairness.

MANAGE: gestionar y mitigar los riesgos

La función Manage prioriza y responde a los riesgos identificados en Map y medidos en Measure. Incluye: implementar controles para mitigar los riesgos priorizados, gestionar incidentes cuando los riesgos se materializan, gestionar los riesgos de terceros (proveedores en la cadena de valor de IA), y documentar y monitorizar todas las actividades de gestión de riesgos de IA. En 2025, las organizaciones más maduras integran el Manage del AI RMF con sus plataformas de GRC (Governance, Risk, Compliance) existentes.

SECCIÓN 3 · CÓMO FUNCIONA

Integración del NIST AI RMF con otros frameworks

El NIST AI RMF está diseñado para integrarse con frameworks existentes. Integración con ISO/IEC 42001: la función Govern del AI RMF se mapea al sistema de gestión de IA (AIMS) de ISO 42001; Map corresponde al análisis de contexto e identificación de riesgos; Measure corresponde a la evaluación del desempeño; Manage corresponde al ciclo PDCA (Plan-Do-Check-Act). Integración con el EU AI Act: Map produce la documentación técnica del Art. 11; Measure produce las evaluaciones de calidad del Art. 9 y 10; Manage produce el sistema de gestión de riesgos del Art. 9. Integración con ISO 27001: el AI RMF extiende el ISMS de ISO 27001 con riesgos específicos de IA.

El NIST AI RMF Playbook (disponible en airc.nist.gov) proporciona métodos y acciones concretas para implementar cada subcategoría del framework. El Playbook tiene más de 200 acciones sugeridas con descripción, responsable típico, y recursos de referencia. Es la guía práctica más completa disponible para implementar el AI RMF en organizaciones reales.

SECCIÓN 4 · EJEMPLOS REALES

- Institución financiera con sistema de scoring de crédito (caso documentado en NIST): adoptó ISO 42001 primero (para establecer el AIMS) y luego usó el NIST AI RMF para la gestión de riesgos continua. Govern: política de IA responsable aprobada por el Consejo. Map: inventario de los 7 sistemas de IA de la institución con sus riesgos. Measure: evaluación de fairness mensual del scoring (distribución de scores por grupo demográfico). Manage: proceso de revisión de los casos con scores borderline por un comité humano. Resultado: reducción del 40% en las quejas de clientes sobre discriminación.
- Amazon (referencia pública): Amazon ha publicado su aplicación del NIST AI RMF a sus servicios de IA de AWS (Rekognition, Comprehend, Textract). Govern: política de Responsible AI con 6 principios. Map: inventario de todos los servicios de IA de AWS con sus riesgos potenciales. Measure: red teaming continuo y fairness evaluations. Manage: process de escalada para incidentes de IA con SLA definido.

SECCIÓN 5 · ERRORES Y MALENTENDIDOS COMUNES

Error 1: Tratar el AI RMF como un checklist estático. El AI RMF es un framework iterativo para gestión continua de riesgos, no una checklist que se completa una vez. Los riesgos evolucionan con el sistema y con el entorno. Las cuatro funciones deben ejecutarse

como un ciclo continuo, no como un proyecto puntual.

Error 2: Implementar el AI RMF en silos. El AI RMF requiere colaboración entre múltiples disciplinas: técnicos de IA, equipos de riesgo y cumplimiento, asesores legales, representantes de usuarios afectados, y la dirección. Un AI RMF implementado solo por el equipo técnico produce governance incompleta.

Error 3: No adaptar el AI RMF al contexto específico de la organización. El AI RMF es un framework genérico que debe adaptarse al sector, al tipo de sistemas de IA, y al nivel de madurez de la organización. Una empresa de salud necesita enfatizar las categorías de riesgo de privacidad y decisión médica. Una empresa financiera necesita enfatizar fairness y explicabilidad.

SECCIÓN 6 · APLICACIÓN PRÁCTICA

Implementación mínima del NIST AI RMF: Govern: adoptar una política de IA responsable con principios claros y asignar un AI Risk Officer. Map: crear el inventario de sistemas de IA con los campos recomendados por el AI RMF (propósito, datos, stakeholders, exposición al riesgo). Measure: implementar evaluaciones periódicas de los atributos de trustworthy AI para cada sistema de alto riesgo. Manage: crear un proceso de revisión mensual de las métricas de riesgo y un protocolo de respuesta a incidentes. Con estos cuatro elementos, la organización tiene una implementación básica pero funcional del AI RMF.

El crosswalk EU AI Act / NIST AI RMF / ISO 42001: muchas organizaciones tienen que cumplir con múltiples frameworks simultáneamente. El crosswalk (mapeo de controles equivalentes entre frameworks) reduce el esfuerzo de cumplimiento. NIST ha publicado crosswalks con ISO 42001 y otros frameworks. Una herramienta de GRC que soporte múltiples frameworks (como Vanta, Drata, o Scrut) puede automatizar la recogida de evidencias y mapearlas simultáneamente a múltiples frameworks.

SECCIÓN 7 · RELACIÓN CON OTROS MÓDULOS

- M13-T1 (EU AI Act): el NIST AI RMF proporciona el framework de gestión que implementa los requisitos técnicos del AI Act.
- M13-T4 (ISO/IEC 42001): ISO 42001 y el NIST AI RMF son complementarios; ISO aporta la estructura certificable, NIST aporta la profundidad en gestión de riesgos.
- M13-T8 (Auditoría de modelos): el AI RMF Measure function incluye la auditoría de modelos como herramienta de evaluación.

SECCIÓN 8 · RESUMEN EJECUTIVO

El NIST AI RMF 1.0 (enero 2023) es el framework de gestión de riesgos de IA más influyente. Sus cuatro funciones son: Govern (cultura y políticas), Map (inventario y categorización de riesgos), Measure (evaluación con 7 atributos: validez, seguridad, fiabilidad, accountability, explicabilidad, privacidad, fairness), y Manage (mitigación y respuesta). El perfil NIST-AI-600-1 (julio 2024) especifica 12 riesgos de IA generativa. El AI RMF integra naturalmente con ISO 42001, el EU AI Act, e ISO 27001. El Playbook (airc.nist.gov) proporciona más de 200 acciones concretas de implementación. Implementación mínima: política + inventario + evaluaciones periódicas + proceso de

revisión.